

SIMATS ENGINEERING
ASSESSMENT TOOL 01

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1408

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

QUESTIONS: 01

Total Marks:100

Annexure A

SECURITY TESTING SIMULATION TASK

Code of Conduct:

I ___P.Ranjithkumar (192411119)_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:PRKY

Question 1: Web Server Reconnaissance and Vulnerability Analysis

A cybersecurity analyst is assigned an authorized and isolated vulnerable web server for a security assessment. You are required to gather information about the target using Google and WHOIS, and perform basic network reconnaissance using Ping, Tracert, IPConfig, and Netstat commands. Use Nmap to identify open ports, running services, and service versions. Use WhatWeb to identify the web technologies and frameworks used by the server. Examine HTTP response headers using Curl/Wget and identify information disclosure. Perform CGI and web-server vulnerability scanning using Nikto, and use Gobuster/Dirb to discover hidden directories and files. Analyze the identified administrative pages, backup files, configuration files, and vulnerable resources. Finally, classify the findings based on severity and impact, and recommend appropriate web-server hardening and information-disclosure prevention measures. Submit the commands executed, screenshots, observations, findings, and recommendations.

Question 2: Web Application Vulnerability Assessment

A cybersecurity analyst is assigned an authorized vulnerable web application in an isolated laboratory environment for security testing. You are required to identify the application's technologies and attack surface using appropriate reconnaissance techniques, examine input fields, parameters, cookies, sessions, and HTTP requests, and use suitable tools to identify vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), insecure authentication, session-management weaknesses, directory traversal, and security misconfigurations. Use tools such as Burp Suite, OWASP ZAP, Nikto, Nmap, Curl, and browser developer tools to analyze the application. Test the identified vulnerabilities only within the authorized laboratory environment, document the evidence and potential impact of each finding, classify the vulnerabilities according to severity, and recommend appropriate remediation and secure coding practices. Submit the commands/tool configurations, screenshots, observations, vulnerability findings, severity ratings, impacts, and recommendations.

Question 3: Security Header and HTTPS Configuration Assessment

A cybersecurity analyst is assigned an authorized web application hosted in an isolated laboratory environment to assess its HTTPS and security-header configuration. You are required to use Curl to examine HTTP response headers and Nmap SSL scripts to analyze the server's HTTPS/TLS configuration. Identify missing or improperly configured security

headers such as Content-Security-Policy (CSP), HSTS, X-Frame-Options, and X-Content-Type-Options, and verify whether HTTP requests are automatically redirected to HTTPS. Examine the TLS configuration for weak protocols, insecure cipher suites, and certificate-related issues. Analyze the security purpose and potential impact of each misconfiguration, classify the findings according to their severity, and recommend appropriate HTTPS, TLS, certificate, and security-header hardening measures. Submit the commands used, screenshots, observations, identified risks, severity classification, and remediation recommendations.

Question 4: Broken Access-Control Assessment

A cybersecurity analyst is assigned an authorized student portal in an isolated laboratory environment containing separate student and administrator test accounts. Using OWASP ZAP, capture and analyze requests generated while accessing student records and identify test object identifiers in URLs, forms, cookies, or API requests. Using only the test identifiers provided by the faculty, determine whether one student account can access another student's records or whether a normal user can directly access administrator-only resources. Compare the server responses for authorized and unauthorized requests, explain the difference between authentication and authorization failures, classify the identified access-control weaknesses based on their severity and impact, and recommend appropriate server-side authorization checks, role validation, and secure object-reference mechanisms. Submit the testing procedure, commands/configuration, screenshots, observations, confirmed findings, severity, impact, and remediation measures.

Question 5: Automated Scanning and Manual Validation

A cybersecurity analyst is assigned an authorized web application hosted in a controlled cybersecurity laboratory for vulnerability assessment. Use Nikto to identify web-server misconfigurations and outdated components, and use Wapiti or OWASP ZAP to perform an automated web-application security scan. Compare the vulnerabilities reported by the selected tools and categorize them into misconfiguration, information disclosure, authentication, and injection issues. Select at least three findings for safe manual validation within the authorized laboratory environment and determine whether each finding is confirmed, a false positive, or requires further investigation. Assign an appropriate severity level based on likelihood and potential impact, and recommend practical remediation measures for all confirmed vulnerabilities. Submit a comparative report containing tool outputs, screenshots, validation evidence, severity classification, remediation measures, and overall conclusions.

Question 1: Web Server Reconnaissance and Vulnerability Analysis

Objective

To assess an authorized web server by collecting basic network information, identifying ports and services, detecting web technologies, analyzing HTTP headers, scanning for weaknesses, and locating accessible directories and files.

Target and Tools

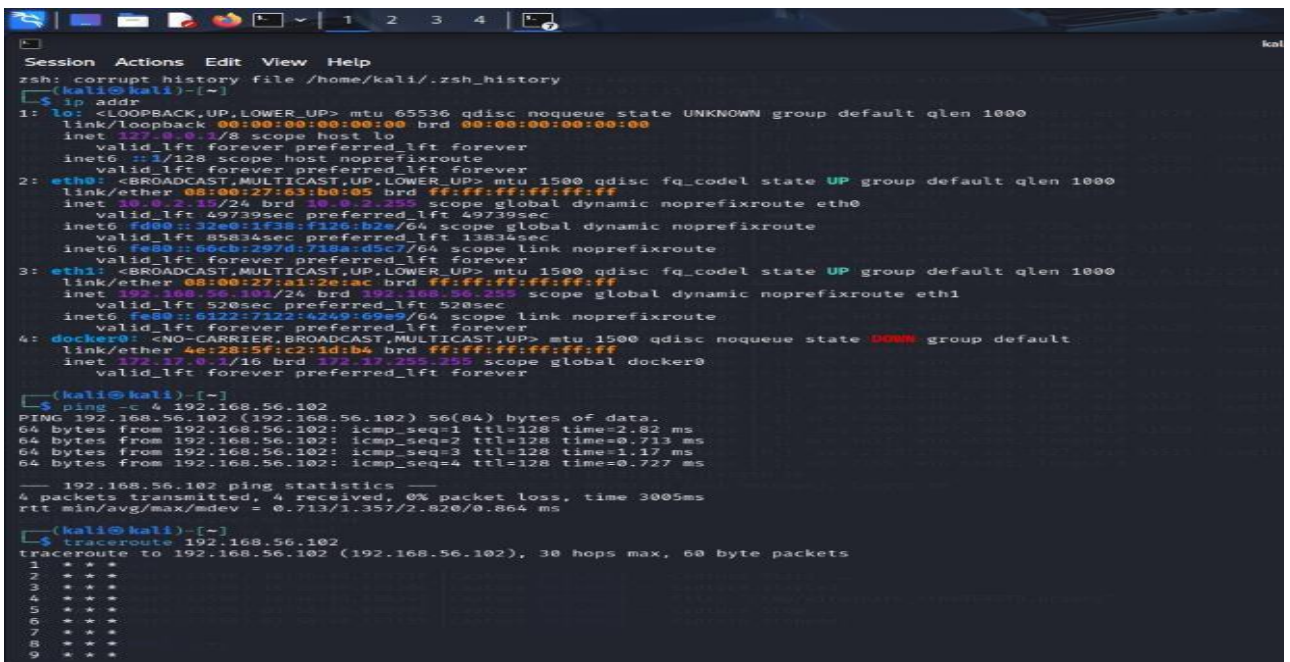
Target IP: 192.168.56.102

Target: Metasploitable 2

Tools: Ping, Traceroute, Netstat, Nmap, WhatWeb, Curl, Wget, Nikto, Gobuster and Dirb.

Procedure and Commands

1. ping -c 4 192.168.56.102



```
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
   inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 49739sec preferred_lft 49739sec
   inet6 fd00::32ee:1f38:f126:b2a/64 scope global dynamic noprefixroute
       valid_lft 85834sec preferred_lft 13834sec
   inet6 fe80::66cb:297d:718a:d5c7/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:a1:2e:ac brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
       valid_lft 520sec preferred_lft 520sec
   inet6 fe80::6122:7122:4249:69e9/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 4e:28:5f:c2:1d:b4 brd ff:ff:ff:ff:ff:ff
   inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever

(kali@kali)~$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=128 time=2.82 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=128 time=0.713 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=128 time=1.17 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=128 time=0.727 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 0.713/1.357/2.820/0.864 ms

(kali@kali)~$ traceroute 192.168.56.102
traceroute to 192.168.56.102 (192.168.56.102), 30 hops max, 60 byte packets
 1  * * *
 2  * * *
 3  * * *
 4  * * *
 5  * * *
 6  * * *
 7  * * *
 8  * * *
 9  * * *
```

Observation: The target responded successfully with 0% packet loss.

Observation: Displayed listening ports and network connections.

4. nmap 192.168.56.102

5. nmap -sV 192.168.56.102

Observation: Multiple services were identified, including ports 135, 139 and 445 associated with MSRPC, NetBIOS and Microsoft-DS/SMB.

6. whatweb http://192.168.56.102

Observation: Apache 2.2.8, Ubuntu Linux, PHP 5.2.4 and WebDAV were detected with HTTP 200 OK.

7. curl -I http://192.168.56.102

8. wget --server-response --spider http://192.168.56.102

Observation: Server platform and PHP information were exposed.

9. nikto -h http://192.168.56.102

Observation: Checked for outdated software, misconfigurations and exposed resources.

10. gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt

11. dirb http://192.168.56.102

Observation: Accessible directories and files were identified.

Findings and Severity

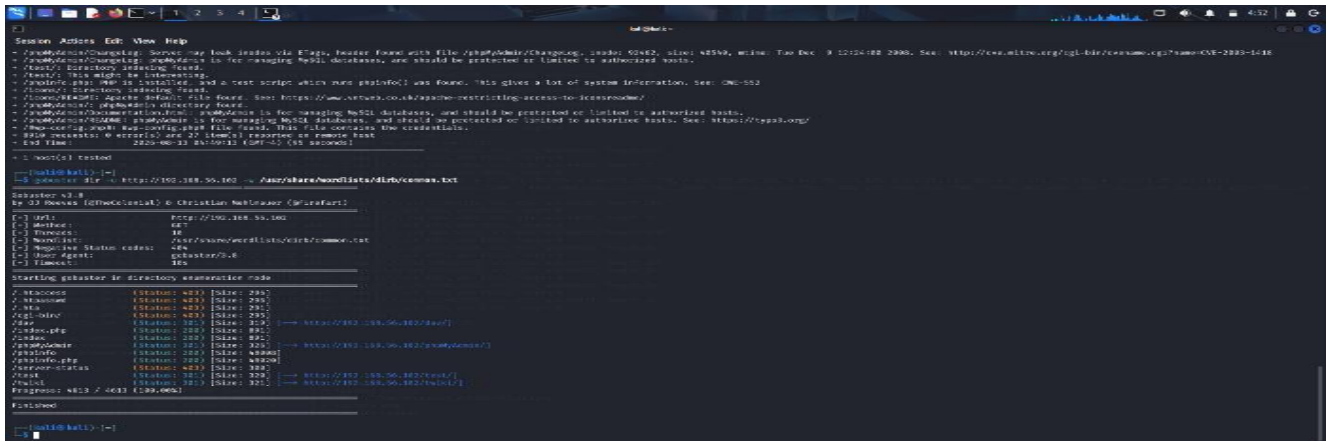
Server/PHP version disclosure — Low

Outdated Apache/PHP versions — High

WebDAV exposure — Medium

Exposed directories/resources — Medium

Unnecessary network services — Medium



Recommendations

Perform regular vulnerability assessments and server hardening.

Hide unnecessary version information.

Disable WebDAV if not required.

Close unused ports and services.

Configure appropriate HTTP security headers.

Conclusion

The assessment identified network exposure, outdated software, information disclosure, WebDAV exposure and accessible resources that should be addressed to improve server security.

Question 2: Web Application Vulnerability Assessment

Aim

To perform a vulnerability assessment of an authorized web application using Nmap, Nikto, Burp Suite and OWASP ZAP in a controlled laboratory environment.

Target and Tools

Target: 192.168.56.102

Application: Damn Vulnerable Web Application (DVWA)

Operating System: Metasploitable 2 / Linux

Tools: Nmap, WhatWeb, Nikto, Burp Suite and OWASP ZAP.

Procedure and Commands

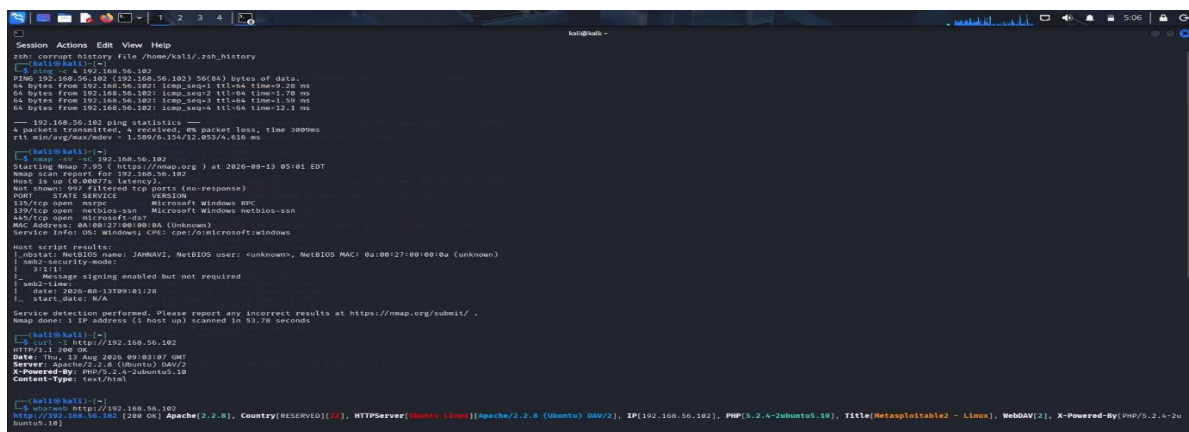
ping -c 4 192.168.56.102

nmap -sV -sC 192.168.56.102

curl -I http://192.168.56.102

whatweb http://192.168.56.102

nikto -h <http://192.168.56.102>



```
Session Actions Edit View Help
kali@kali: ~
zsh: corrupt history file /home/kali/.zsh_history

kali@kali:~$ ping -c 4 192.168.56.102
PING 192.168.56.102 (192.168.56.102) 56(84) bytes of data:
64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=0.28 ms
64 bytes from 192.168.56.102: icmp_seq=2 ttl=64 time=1.78 ms
64 bytes from 192.168.56.102: icmp_seq=3 ttl=64 time=1.59 ms
64 bytes from 192.168.56.102: icmp_seq=4 ttl=64 time=12.1 ms

--- 192.168.56.102 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 300ms
rtt min/avg/max/mdev = 1.589/6.154/12.053/4.616 ms

kali@kali:~$ nmap -sV -sC 192.168.56.102
Starting Nmap 7.92 ( https://nmap.org ) at 2026-08-13 05:01 EDT
Nmap scan report for 192.168.56.102
Host is up (0.00077s latency).
Not shown: 655 filtered ports (no-response)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds?
MAC Address: 08:00:27:00:00:0A (Unknown)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

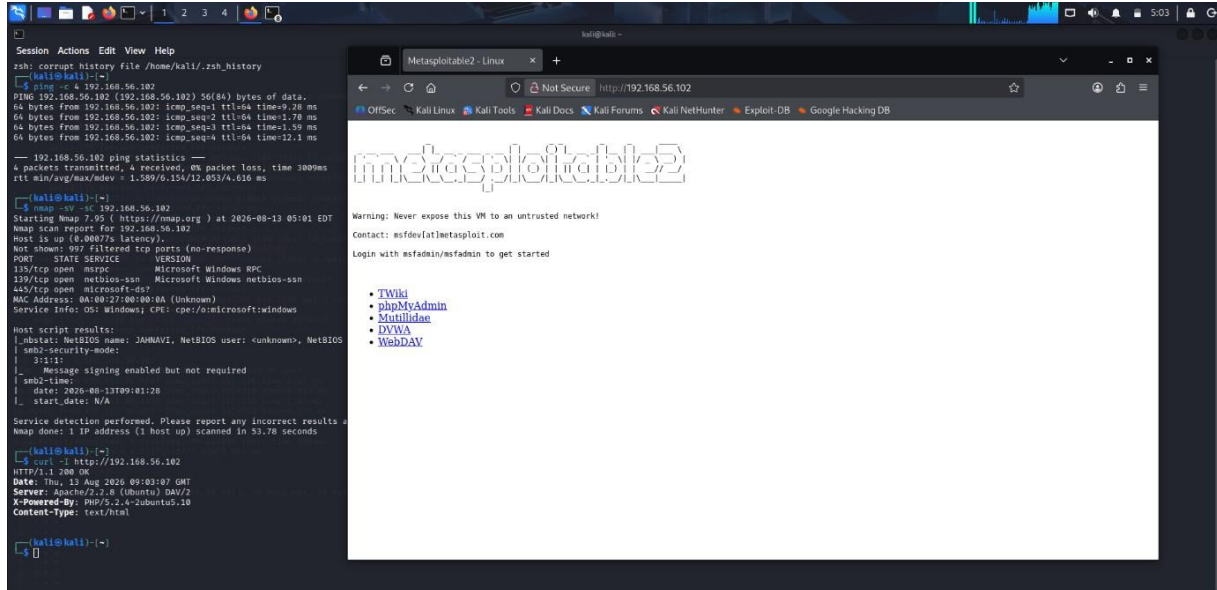
Host script results:
|_ dbxkit: NetBIOS name: 2008AV1, NetBIOS user: <unknown>, NetBIOS MAC: 0a:00:27:00:00:0a (unknown)
|_ smb2security-mode:
|   |_ 11111
|   |_ Message signing enabled but not required
|_ smb-enum:
|   |_ date: 2026-08-13T09:01:28
|   |_ start-date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 53.76 seconds

kali@kali:~$ curl -I http://192.168.56.102
HTTP/1.1 200 OK
Date: Thu, 13 Aug 2026 05:03:57 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html

kali@kali:~$
kali@kali:~$ curl http://192.168.56.102
http://192.168.56.102 (200 OK) Apache[2.2.8], Country[RESERVED][62], HTTPServer[Ubuntu Linux][Apache/2.2.8 (Ubuntu) DAV/2], IP[192.168.56.102], PHP[5.2.4-2ubuntu5.10], Title[Metasploitable2 - Linux], WebDAV[1], X-Powered-By:[PHP/5.2.4-2ubuntu5.10]
```


DVWA security level was configured to Low for controlled testing.



Burp Proxy listener: 127.0.0.1:8080.

GET, POST, login and application requests were captured in HTTP History.

The SQL Injection id parameter and Reflected XSS input were tested only in the authorized lab.

Browser Developer Tools were used to inspect the PHPSESSID cookie.

OWASP ZAP scanned <http://192.168.56.102/dvwa/> and generated 442 requests with 4 new alerts at that stage.

Security Findings

Directory Browsing

Missing Anti-clickjacking Header

Missing Anti-CSRF Tokens

Content Security Policy Header Not Set

Severity and Impact

SQL Injection — High: May affect database confidentiality and integrity.

Reflected XSS — Medium/High: May allow malicious scripts in the user's browser.

Missing Anti-CSRF Tokens — Medium.

Directory Browsing — Low/Medium.

Weak cookie attributes — Medium.

Recommendations

Use parameterized queries.

Validate and encode user input.

Implement CSRF tokens.

Use Secure, HttpOnly and appropriate SameSite cookie attributes.

Configure CSP and anti-clickjacking protection.

[illegible]

Conclusion

The assessment demonstrated the importance of input validation, session protection, HTTP security headers and regular vulnerability scanning.

Question 3: Security Header and HTTPS Configuration Assessment

Aim

To evaluate HTTPS, TLS, certificate and HTTP security-header configuration using Curl and Nmap.

Target and Tools

Target: 192.168.56.102 (Metasploitable 2)

Tools: Curl and Nmap.

Commands Used

```
curl -I http://192.168.56.102
```

```
curl -k -I https://192.168.56.102
```

```
curl -I http://192.168.56.102:443
```

```
nmap -Pn -p 443 --script ssl-enum-ciphers 192.168.56.102
```

```
nmap -Pn -p 443 --script ssl-cert 192.168.56.102
```

Practical Observations

HTTP returned 200 OK with no HTTP-to-HTTPS redirect. The HTTPS request failed with a wrong version number. HTTP on port 443 returned 200 OK, indicating that port 443 was serving HTTP instead of properly negotiating TLS. Nmap could not enumerate TLS ciphers or certificate information.

Findings and Severity

Missing HTTP-to-HTTPS redirection — Medium

Missing CSP, HSTS, X-Frame-Options and X-Content-Type-Options — Medium/Low

Improper HTTPS/TLS configuration on port 443 — High

Remediation

Configure Apache correctly for HTTPS on port 443.

Use valid TLS certificates.

Redirect HTTP to HTTPS.

Disable obsolete TLS protocols and weak ciphers.

Implement CSP, HSTS, X-Frame-Options and X-Content-Type-Options.

```
kali@kali:~$ cat /home/kali/.zsh_history
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ curl -I https://192.168.56.102
curl: (35) TLS connect error: error:0A00010B:SSL routines::wrong version number

kali@kali:~$ curl -I https://192.168.56.102:443
HTTP/1.1 200 OK
Date: Thu, 13 Aug 2020 12:13:11 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
Powered-By: mod_2.2.4-ubuntu5.18
Content-Type: text/html

kali@kali:~$ ssh -o HostKeyAlgorithms=ssh-rsa -o PubkeyAcceptedAlgorithms=ssh-rsa msfadmin@192.168.56.102
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded, see https://openssh.com/pu.html
msfadmin@192.168.56.102:~$ password:
Linux msfadmin@kali: 2.6.32-36-server #1 SMP Thu Apr 10 13:15:08 UTC 2008 1686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Thu Aug 13 07:39:32 2020 from 192.168.56.101
msfadmin@kali:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:Listen 0.0.0.0:80
6:Listen 0.0.0.0:443
msfadmin@kali:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:Listen 0.0.0.0:80
6:Listen 0.0.0.0:443
msfadmin@kali:~$ sudo grep -nE "VirtualHost|SSLEngine|SSLCertificate" /etc/apache2/sites-available/ssl-site
2:VirtualHost *
6:SSLEngine on
6:SSLCertificateFile /etc/apache2/ssl/server.crt
6:SSLCertificateKeyFile /etc/apache2/ssl/server.key
msfadmin@kali:~$ sudo /etc/init.d/apache2 restart
* Restarting web server apache2
[Thu Aug 13 08:16:58 2020] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:16:58 2020] [warn] NameVirtualHost *:8 has no VirtualHosts
[Thu Aug 13 08:17:08 2020] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:17:08 2020] [warn] NameVirtualHost *:8 has no VirtualHosts
...done.
msfadmin@kali:~$ exit
logout
Connection to 192.168.56.102 closed.
```

Result

Multiple security-hardening deficiencies and an improperly configured HTTPS service

```
kali@kali:~$ msfadmin@kali:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:Listen 0.0.0.0:80
4:Listen 0.0.0.0:443
msfadmin@kali:~$ sudo grep -n "Listen" /etc/apache2/ports.conf
1:Listen 0.0.0.0:80
4:Listen 0.0.0.0:443
msfadmin@kali:~$ sudo grep -nE "VirtualHost|SSLEngine|SSLCertificate" /etc/apache2/sites-available/ssl-site
1:NameVirtualHost *
2:VirtualHost *
6:SSLEngine on
6:SSLCertificateFile /etc/apache2/ssl/server.crt
6:SSLCertificateKeyFile /etc/apache2/ssl/server.key
msfadmin@kali:~$ sudo /etc/init.d/apache2 restart
* Restarting web server apache2
[Thu Aug 13 08:16:58 2020] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:16:58 2020] [warn] NameVirtualHost *:8 has no VirtualHosts
[Thu Aug 13 08:17:08 2020] [error] VirtualHost *:443 -- mixing * ports and non-* ports with a NameVirtualHost address is not supported, proceeding with undefined results
[Thu Aug 13 08:17:08 2020] [warn] NameVirtualHost *:8 has no VirtualHosts
...done.
msfadmin@kali:~$ exit
logout
Connection to 192.168.56.102 closed.

kali@kali:~$ curl -k -I https://192.168.56.102
curl: (35) TLS connect error: error:0A00010B:SSL routines::wrong version number

kali@kali:~$ nmap -Pn -p 443 --script ssl-enum-ciphers 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-14 00:12 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0014s latency).

PORT      STATE SERVICE
443/tcp   open  https
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 25.93 seconds

kali@kali:~$ nmap -Pn -p 443 --script ssl-cert 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2020-08-14 00:13 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0015s latency).

PORT      STATE SERVICE
443/tcp   open  https
MAC Address: 08:00:27:73:FB:10 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.38 seconds

kali@kali:~$
```

were identified.

Question 4: Broken Access-Control Assessment

Aim

To use OWASP ZAP to capture and analyze HTTP requests and responses of an authorized vulnerable web application and examine access-control related information.

Tools and Configuration

Kali Linux

OWASP ZAP 2.17.0

Metasploitable 2

Mutillidae web application

Target: <http://192.168.56.102/>

Mutillidae: <http://192.168.56.102/mutillidae/>

ZAP Proxy: 127.0.0.1:8080

Procedure

Started OWASP ZAP and configured the browser to use it as a proxy.

Accessed the authorized laboratory server and Mutillidae.

Captured HTTP requests while navigating the application.

Examined methods, URLs, parameters, cookies, session information and responses.

Compared authorized and unauthorized responses using only faculty-provided test identifiers.

Checked ZAP Alerts for security issues.

Authentication vs Authorization

Authentication verifies who the user is. Authorization determines what an authenticated user is allowed to access. A user may be authenticated successfully but still be improperly authorized to access another user's records or administrator resources.

Findings and Severity

Potential IDOR/Broken Object-Level Authorization — High if one student can access another student's records.

Potential vertical privilege escalation — High if a normal user can access administrator resources.

Session or role validation weakness — Medium/High depending on impact.

Impact and Recommendations

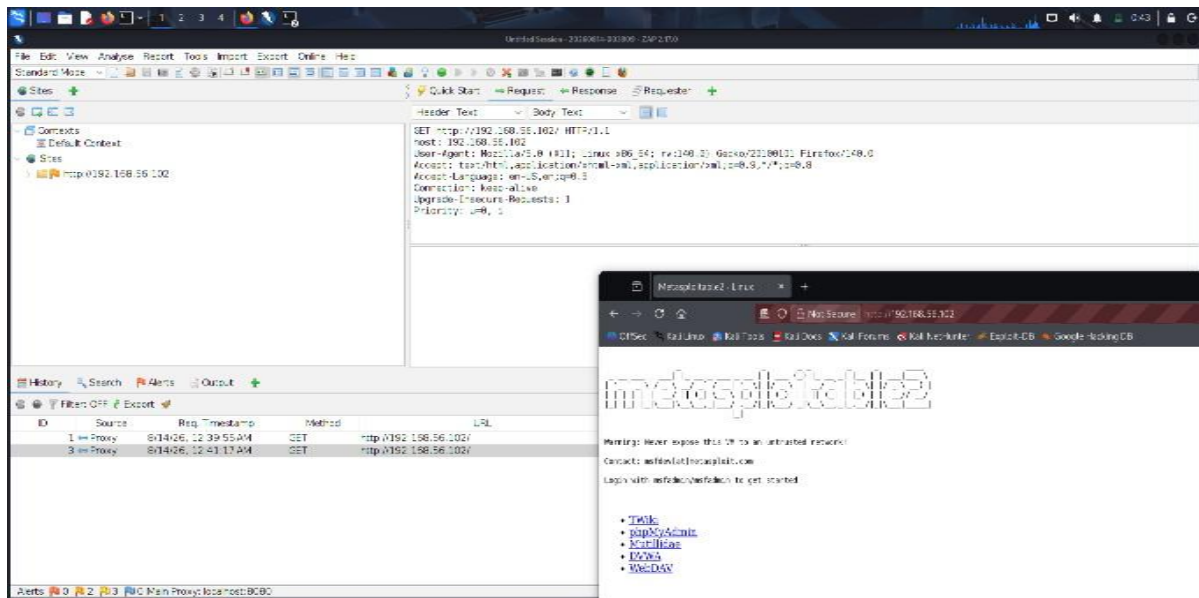
Broken access control may expose confidential records or permit unauthorized modification.

Enforce server-side authorization for every protected request.

Validate object ownership.

Perform role validation for administrator functions.

Do not rely only on hidden fields, URLs or client-side checks.



The screenshot displays the Burp Suite application interface. The top section shows the 'Request' tab with a detailed view of a POST request to `http://192.168.56.102/multi/index.php?page=register.php`. The request body contains a JSON payload for user registration, including fields like `username`, `password`, `email`, and `signature`.

The bottom section shows the 'History' tab with a table of network requests. The table has columns for ID, Source, Req. Timestamp, Method, URL, Code, Reason, RTT, Size Resp. Body, Highest Alert, Note, and Tags.

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
29	Proxy	8/14/2016, 12:44:00 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	170 ms	25,455 bytes	Medium		Form, Password, Script
31	Proxy	8/14/2016, 12:45:26 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	229 ms	23,219 bytes	Medium		Form, Password, Script
32	Proxy	8/14/2016, 12:45:16 AM	POST	http://192.168.56.102/multi/index.php?page=...	200	OK	154 ms	26,311 bytes	Medium		Form, Password, Script
34	Proxy	8/14/2016, 12:47:04 AM	POST	http://192.168.56.102/multi/index.php?page=...	200	OK	46 ms	24,439 bytes	Medium		Form, Password, Script
35	Proxy	8/14/2016, 12:47:56 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	561 ms	2,849 bytes	Medium		Script
37	Proxy	8/14/2016, 12:47:57 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	26 ms	1,734 bytes	Medium		Comment
38	Proxy	8/14/2016, 12:47:56 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	273 ms	23,214 bytes	Medium		Form, Password, Script
39	Proxy	8/14/2016, 12:48:43 AM	POST	http://192.168.56.102/multi/index.php?page=...	200	OK	308 ms	24,433 bytes	Medium		Form, Password, Script
41	Proxy	8/14/2016, 12:51:15 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	149 ms	2,849 bytes	Medium		Script
42	Proxy	8/14/2016, 12:51:22 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	73 ms	23,214 bytes	Medium		Form, Password, Script
43	Proxy	8/14/2016, 12:51:24 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	149 ms	2,849 bytes	Medium		Script
44	Proxy	8/14/2016, 12:51:26 AM	GET	http://192.168.56.102/multi/index.php?page=...	200	OK	57 ms	23,214 bytes	Medium		Form, Password, Script

Conclusion

Any confirmed cross-user or privilege-level access should be treated as a serious access-control weakness and corrected through server-side authorization enforcement.

Question 5: Automated Scanning and Manual Validation

Aim

To identify web-server misconfigurations and web-application vulnerabilities using Nikto and OWASP ZAP, manually validate selected findings, classify severity and recommend remediation.

Target and Tools

Target: 192.168.56.102

Nikto: Web-server vulnerability scanner

OWASP ZAP 2.17.0: Web-application security scanner

Browser and Curl: Manual validation.

Nikto Findings

Apache/2.2.8 and OpenSSL/0.9.8g outdated components.

Missing security headers.

Directory indexing in /doc/, /test/ and /icons/.

phpinfo.php information disclosure.

phpMyAdmin exposure.

Other server information disclosures.

OWASP ZAP Results

Content Security Policy Header Not Set.

Directory Browsing.

Missing Anti-clickjacking Header.

X-Content-Type-Options Header Missing.

Cookie security issues.

Manual Validation

1. Missing Security Headers

Evidence: curl -I http://192.168.56.102 showed CSP and X-Frame-Options were absent.

Result: Confirmed.

Severity: Low/Medium.

2. Directory Browsing

Evidence: /doc/ displayed Index of /doc with directory contents.

Result: Confirmed.

Severity: Medium.

3. Information Disclosure

Evidence: Nikto identified phpinfo.php and browser validation confirmed accessible information disclosure.

Result: Confirmed.

Severity: Medium.

Comparison

Nikto provided stronger server-level findings such as outdated software, directory indexing, phpinfo exposure and server misconfiguration. OWASP ZAP provided broader application and HTTP findings including security headers, cookies, directory browsing and application alerts.

Remediation

Upgrade outdated Apache, OpenSSL and other components.

Disable unnecessary directory listing.

Remove or restrict phpinfo.php and administrative tools.

Configure CSP, X-Frame-Options and X-Content-Type-Options.

Secure cookies using appropriate attributes.

Re-scan and manually validate after remediation.

```
kali@kali:~$ zsh
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ nikto -h http://192.168.56.102
- Nikto v2.3.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2020-08-14 01:10:28 (GMT+4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_ssl/2.2.8 OpenSSL/0.9.8g
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.18.
+ /: The anti-clickjacking x-frame-options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.force.imcloud.com/vulnerabilities/2175
+ mod_ssl/2.2.8 appears to be outdated (current is at least 2.9.6) (may depend on server version).
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OpenSSL/0.9.8g appears to be outdated (current is at least 3.0.2). OpenSSL 3.0 is current for the 1.x branch and will be supported until Nov 11 2023.
+ mod_ssl/2.2.8 OpenSSL/0.9.8g - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.
+ /: Web Server returns a valid response with Junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /PHPBB32F2A0-3C92-11d3-A3AF-4C7B8C1B0800: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /PHPBB32F2A0-3C92-11d3-A3AF-4C7B8C1B0800: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /PHPBB32F2A0-3C92-11d3-A3AF-4C7B8C1B0800: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/ChangeLog: Server may leak index via ETags, header found with file /phpMyAdmin/ChangeLog. Inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-icons/readme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /php-config.php: php-config.php file found. This file contains the credentials.
+ 8918 requests: 0 error(s) and 30 item(s) reported on remote host
+ End Time: 2020-08-14 01:11:33 (GMT+4) (65 seconds)

+ 1 host(s) tested

kali@kali:~$
kali@kali:~$ zmap
Found 300 version 21.0.0
Available memory: 1971 MB
```

The screenshot displays the Burp Suite application interface. On the left, a list of detected issues is shown, including 'Application Error Disclosure (32)', 'Content Security Policy (CSP) Header Not Set', 'Directory Browsing (2)', 'Missing Anti-Clickjacking Header (Systemic)', 'Vulnerable JS Library', 'Big Redirect Detected (Potential Sensitive Info)', 'Cookie No HttpOnly Flag (4)', 'Cookie without SameSite Attribute (Systemic)', 'In Page Banner Information Leak (Systemic)', 'Information Disclosure - Debug Error Message', 'Private IP Disclosure (6)', 'Server Leaks Information via "X-Powered-By"', 'X-Content-Type-Options Header Missing (Systemic)', 'Authentication Request Identified (5)', and 'Information Disclosure - Suspicious Comment'. The 'Information Disclosure - Suspicious Comment' issue is selected and expanded on the right.

Information Disclosure - Suspicious Comment

URL: http://192.168.56.102/multilide/

Risk: Informational

Confidence: Medium

Parameter: user

Attack: WASC ID: 615

Evidence: user

WASC ID: 13

Source: Passive (10027 - Information Q

Description: The response appears to contain suspicious comments which may help an attacker.

Other Info: The following pattern was used: 'USERB' and was detected in likely comment: '<!-- I think the database password is set to blank or perhaps samu... it they refer to.

Solution: Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.

Alert Tags: OWASP_2021_A01, WSTG-v42-WF-0-05, OWASP_2017_A03, POLICY_REVIEW, CWE-615

References: https://owasp.org/Top10/A01_2021-4, https://owasp.org/www-project-web-security-top10, https://owasp.org/www-project-top10, https://cve.mitre.org/data/definitions/

